DATAVAULT BANK - VERİTABANI GÜVENLİĞİ DENETİM RAPORU

Denetlenen Kurum: DataVault Bank

Sistem: Oracle Database 19c Enterprise Edition (DATAVAULTPRD - Production)

Denetçi: Necdet Emre Bayraktar (Bilgi Sistemleri Denetçisi)

1. Yönetici Özeti

Bu denetim çalışması, DataVault Bank'ın kritik müşteri verilerini barındıran Oracle veritabanı (DATAVAULTPRD) altyapısının güvenlik, erişim kontrolleri ve operasyonel süreçlerinin değerlendirilmesi amacıyla gerçekleştirilmiştir. Veritabanı yöneticileri; yetkilerin minimum seviyede olduğu, hassas verilerin korunduğu ve şifrelendiği, veritabanının güncel olduğu, loglamanın etkin olduğu, görevler ayrılığının uygulandığı ve varsayılan hesapların kapatıldığı yönünde güvence vermiştir.

Yapılan incelemeler sonucunda, sistemin temel operasyonel işlevlerini yerine getirdiği görülmekle birlikte, verilen güvencelerin büyük bölümünün teknik kanıtlarla desteklenmediği tespit edilmiştir. Uygulama, raporlama, geliştirme ve danışman hesaplarına **DBA rolü** atanmış; kredi kartı numaraları, T.C. Kimlik Numaraları ve maaş verileri **şifrelenmeden ve maskelenmeden** tutulmakta; denetim izi (audit_trail) **tamamen kapalıdır**. Ayrıca SYS hesabına yönelik 324 başarısız giriş denemesi bulunması, sistemin aktif bir saldırı veya ciddi bir yapılandırma hatasıyla karşı karşıya olduğuna işaret etmektedir.

Özellikle erişim yönetiminin sıkılaştırılması, hassas verilerin şifrelenmesi ve izlenebilirlik (loglama) mekanizmalarının devreye alınması, kurumun siber güvenlik duruşunu ve PCI-DSS, KVKK/GDPR uyumluluğunu önemli ölçüde güçlendirecektir.

2. Denetim Kapsamı

Bu denetim; 2,3 TB boyutunda ve 42.318.441 kayıt barındıran, sahibi BANKDBA olan DATAVAULTPRD üretim veritabanının aşağıdaki bileşenlerini kapsamaktadır:

- Kimlik ve Erişim Yönetimi (kullanıcılar, roller ve sistem yetkileri)
- Parola Politikaları ve Kimlik Doğrulama
- Veri Güvenliği, Şifreleme ve Hassas Veriler
- Denetim İzi (Loglama) ve İzleme
- Yedekleme ve Felaket Kurtarma
- Yama Yönetimi ve Database Link Entegrasyonları
- Değişiklik Yönetimi

Yapılan Testler

Denetim, kurum tarafından paylaşılan sorgu çıktıları üzerinden gerçekleştirilmiştir: dba_users, dba_role_privs ve dba_sys_privs ile kullanıcı ve yetki analizi; dba_profiles ve password_versions ile parola politikası ve hash analizi; dba_tables, örnek veri ve dba_tablespaces ile hassas veri ve şifreleme kontrolü; audit parametresi, RMAN yapılandırması, v$instance, dba_db_links, başarısız girişler, aktif oturumlar (v$session) ve değişiklik kayıtlarının (Change Log) incelenmesi.

3. Yönetim Beyanları ve Denetim Sonuçları

Yönetim Beyanı	Sonuç	Kanıt
Yetkiler minimum seviyededir.	Karşılanmıyor	APPUSER, REPORTUSER, DEVTEAM ve TEMPCONSULTANT hesaplarında DBA rolü (Bulgu 4.1.1).
Hassas veriler korunmaktadır.	Karşılanmıyor	Kredi kartı, T.C. Kimlik No ve maaş verileri açık metin (Bulgu 4.3.2).
Şifreleme kullanılmaktadır.	Karşılanmıyor	Tüm tablespace'lerde ENCRYPTED = NO; yedek şifrelemesi OFF (Bulgu 4.3.1, 4.5.1).
Ayrıcalıklı erişimler gözden geçirilmektedir.	Karşılanmıyor	Atıl hesaplar OPEN, danışman hesabında DBA rolü (Bulgu 4.1.1, 4.1.2).
Veritabanı günceldir.	Karşılanmıyor	Oracle 19.3.0.0 taban sürüm, yama uygulanmamış (Bulgu 4.6.1).
Loglama etkin durumdadır.	Karşılanmıyor	audit_trail = NONE (Bulgu 4.4.1).
Görevler ayrılığı uygulanmaktadır.	Karşılanmıyor	Canlı ortamda test/geliştirme hesapları ve DBA yetkisi (Bulgu 4.1.1, 4.1.3).
Varsayılan hesaplar kapatılmıştır.	Karşılanmıyor	SYS, SYSTEM ve DBSNMP hesapları OPEN durumdadır.

4. Tespit Edilen Bulgular

4.1 Kimlik ve Erişim Yönetimi (IAM)

Bulgu 4.1.1 - Üretim Ortamında Görevler Ayrılığı İhlali ve Aşırı Yetkilendirme: Üretim ortamında (DATAVAULTPRD) yer alan APPUSER, REPORTUSER, DEVTEAM ve TEMPCONSULTANT hesaplarına veritabanındaki en üst düzey yetki seti olan DBA rolünün atandığı tespit edilmiştir. Ayrıca sadece okuma yapması beklenen REPORTUSER hesabının EXECUTE ANY PROCEDURE yetkisine sahip olduğu görülmüştür.

- **Risk:** Uygulama, raporlama, geliştirme ve danışman hesaplarının DBA yetkisine sahip olması yetkisiz veri manipülasyonu, sistem kesintisi ve iç tehdit risklerini artırmaktadır. Bu

durum "Görevler Ayrılığı (Segregation of Duties)" ve "En Az Yetki (Least Privilege)" prensiplerine aykırıdır.

- **Öneri:** Tüm hesap yetkileri gözden geçirilmeli, DBA rolü yalnızca asıl veritabanı yöneticilerinde kalacak şekilde sınırlandırılmalıdır. Raporlama ve uygulama hesaplarına yalnızca iş süreçlerinin gerektirdiği minimum yetkiler (SELECT, INSERT, UPDATE vb.) tanımlanmalıdır.
- **Risk Seviyesi: Critical**

Bulgu 4.1.2 - Atıl Durumdaki Kullanıcı Hesaplarının Açık Olması: 2023 yılında oluşturulan TEMPCONSULTANT hesabının en son 03.02.2025 tarihinde kullanılmasına rağmen hâlâ OPEN statüsünde olduğu görülmüştür. Benzer şekilde TESTUSER (son giriş: 2024) ve LEGACYAPP (son giriş: 2023) hesapları da uzun süredir kullanılmamalarına rağmen erişime açıktır.

- **Risk:** Atıl hesapların kapatılmaması, bu hesapların yetkisiz kişiler veya kötü niyetli yazılımlar (ör. kaba kuvvet saldırıları) tarafından ele geçirilerek sisteme sızılması riskini doğurur.
- **Öneri:** Belirli bir süre (ör. 90 gün) kullanılmayan hesapları otomatik kilitleyen bir mekanizma devreye alınmalı, tespit edilen atıl hesaplar derhal kilitlenmeli veya silinmelidir.
- **Risk Seviyesi: High**

Bulgu 4.1.3 - Üretim Ortamında Test ve Geliştirme Hesaplarının Bulunması: Canlı ortamda TESTUSER (Test Kullanıcısı) ve DEVTEAM (Geliştirici Ekibi) hesaplarının yer aldığı ve aktif olduğu tespit edilmiştir.

- **Risk:** Canlı veritabanı üzerinde test ve geliştirme faaliyetlerinin yürütülmesi, canlı verinin bozulması, hatalı işlemler sonucu sistem kesintisi ve müşteri verilerinin ifşası riskini taşır.
- **Öneri:** Canlı ortam ile test/geliştirme ortamları kesin hatlarla ayrılmalı, bu hesaplar üretimden kaldırılmalı ve testler maskelenmiş verilerle ayrı bir test veritabanında yapılmalıdır.
- **Risk Seviyesi: High**

4.2 Parola Yönetimi ve Kimlik Doğrulama Zafiyetleri

Bulgu 4.2.1 - Eksik Parola Politikaları ve Kaba Kuvvet (Brute-Force) Saldırı Riski: DEFAULT profilde parola geçerlilik süresi (PASSWORD_LIFE_TIME) ve başarısız giriş limiti (FAILED_LOGIN_ATTEMPTS) UNLIMITED olarak ayarlanmış, parola karmaşıklığını zorunlu kılan PASSWORD_VERIFY_FUNCTION devre dışıdır (NULL). SYS hesabına yönelik 324, SYSTEM hesabına yönelik 119 başarısız giriş denemesi tespit edilmiştir.

- **Risk:** Karmaşıklık, düzenli değişim ve hesap kilitleme mekanizmalarının olmaması sistemi kaba kuvvet saldırılarına karşı tamamen savunmasız bırakmaktadır. En yetkili hesap olan SYS'deki yüksek sayıdaki başarısız giriş, halihazırda bir saldırının veya yapılandırma hatasının gerçekleştiğine işaret etmektedir.

- **Öneri:** Parola doğrulama fonksiyonu derhal devreye alınmalı, parolalar periyodik olarak (ör. 90 günde bir) değiştirilmeli ve 3-5 başarısız deneme sonrası hesap kilitlenmelidir. SYS hesabına yönelik başarısız girişlerin kaynağı (IP/uygulama) acilen incelenmelidir.
- **Risk Seviyesi: Critical**

Bulgu 4.2.2 - Zayıf ve Demode Parola Özetleme (Hash) Algoritmaları: SYS, SYSTEM, APPUSER ve LEGACYAPP dahil birçok kullanıcının parolalarının hâlâ zayıf 10G ve 11G versiyonlarıyla saklandığı tespit edilmiştir.

- **Risk:** 10G ve 11G hash algoritmaları günümüzde demode kabul edilmekte olup "çevrimdışı kırma (offline cracking)" yöntemleriyle çok kısa sürede çözülebilmektedir.
- **Öneri:** Parolalar 12C veya daha güçlü algoritmalara yükseltilmeli, 10G/11G formatlarına izin veren yapılandırmalar kapatılmalıdır.
- **Risk Seviyesi: High**

4.3 Veri Güvenliği, Şifreleme ve Hassas Veri İhlalleri

Bulgu 4.3.1 - Şifreleme (Encryption) Eksikliği: SYSTEM, USERS, COREBANK ve CUSTOMERDATA tablespace'lerinde veri şifrelemesinin (ENCRYPTED) kapalı (NO) olduğu görülmüştür. Kritik tabloların sahibi COREBANK olmasına rağmen veriler diskte korumasız tutulmaktadır.

- **Risk:** Hassas verilerin diskte şifrelenmeden saklanması, sunucuya veya depolama birimlerine fiziksel ya da işletim sistemi seviyesinde yetkisiz erişimde tüm bankacılık verilerinin kolayca çalınmasına olanak tanır.
- **Öneri:** Şeffaf Veri Şifreleme (Transparent Data Encryption - TDE) devreye alınmalı; müşteri, kredi kartı ve hesap verilerini barındıran tüm tablespace'ler güçlü algoritmalarla (ör. AES-256) şifrelenmelidir.
- **Risk Seviyesi: Critical**

Bulgu 4.3.2 - Kredi Kartı ve Hassas Verilerin Maskelenmeden (Plain Text) Tutulması: CREDIT_CARDS tablosundaki kredi kartı numaralarının (ör. 4111111111111111) düz metin olarak saklandığı, CUSTOMERS tablosundaki T.C. Kimlik Numaraları ile EMPLOYEES tablosundaki maaş verilerinin açıkça görüntülenebildiği tespit edilmiştir. Aşırı yetkilendirilmiş hesaplar nedeniyle (Bkz. Bulgu 4.1.1) bu veriler gereksiz kullanıcılar tarafından okunabilmektedir.

- **Risk:** Kredi kartı verilerinin açık tutulması PCI-DSS gereksinimlerinin en ağır ihlallerinden biridir. Kimlik ve maaş bilgilerinin gizlenmemesi KVKK ve GDPR kapsamında ciddi ihlallere ve itibar kaybına neden olabilir.
- **Öneri:** Kredi kartı verileri şifrelenmeli veya geri döndürülemez formatta (tokenization/ masking) tutulmalıdır. Veri Maskeleme (Data Redaction) kuralları uygulanarak kişisel ve finansal veriler yalnızca "Bilmesi Gereken (Need-to-Know)" ilkesine göre yetkilendirilmiş kişilerce görülebilmelidir.
- **Risk Seviyesi: Critical**

4.4 Denetim İzi (Loglama) ve Sistem İzleme Eksiklikleri

Bulgu 4.4.1 - Denetim İzlerinin (Audit Trail) Tamamen Kapalı Olması: audit_trail parametresinin NONE olarak ayarlandığı, dolayısıyla sistem üzerinde yapılan işlemlerin kaydedilmediği görülmüştür.

- **Risk:** Loglamanın kapalı olması yetkisiz erişimlerin, veri sızıntılarının veya zararlı değişikliklerin tespit edilmesini imkansız kılar. Olay müdahale (Incident Response) ve adli bilişim (Forensics) süreçlerinde hesap verebilirlik sağlanamaz.
- **Öneri:** Özellikle SYS ve DBA hareketlerini kapsayacak şekilde denetim izleri ivedilikle aktif edilmeli (audit_trail = DB, EXTENDED veya uygun bir yapılandırma) ve loglar merkezi bir SIEM sistemine aktarılarak sürekli izlenmelidir.
- **Risk Seviyesi: Critical**

4.5 Süreklilik ve Felaket Kurtarma (DR) Zafiyetleri

Bulgu 4.5.1 - Yedekleme Stratejisi ve Saklama Politikası (Retention Policy) Eksiklikleri: RMAN (Recovery Manager) yapılandırmasında Retention Policy'nin tanımlı olmadığı (NONE), yedek şifrelemesinin kapalı olduğu (OFF) ve en son başarılı yedeğin 17 Kasım 2025 tarihinde alındığı tespit edilmiştir.

- **Risk:** Canlı ortamda çalışan veritabanının uzun süredir geçerli bir yedeğinin alınmamış olması, donanım arızası, fidye yazılımı (ransomware) saldırısı veya veri bozulması durumunda veri kaybının kesin olacağı anlamına gelir. Şifrelenmemiş yedekler taşınma sırasında veri sızıntısı riski yaratır.
- **Öneri:** Sistemin kritikliğine uygun RPO/RTO hedefleri belirlenerek günlük, haftalık ve aylık yedekleme planları oluşturulmalı; Retention Policy aktif edilmeli ve tüm yedekler şifrelenerek güvenli bir dış lokasyonda saklanmalıdır.
- **Risk Seviyesi: Critical**

4.6 Yama (Patch) Yönetimi ve Entegrasyon Riskleri

Bulgu 4.6.1 - Güncel Olmayan Veritabanı Sürümü: Sistem Oracle Database 19.3.0.0 taban sürümünde çalışmaktadır. Bu durum, sürüm yayınlandığından beri herhangi bir Güvenlik Yama Paketi (Release Update) uygulanmadığını göstermektedir.

- **Risk:** Zaman içinde ortaya çıkan bilinen güvenlik zafiyetleri (CVE) kapatılmadığı için veritabanı saldırganlar tarafından istismar edilebilir (exploit) durumdadır.
- **Öneri:** Kritik güvenlik yamaları (Release Updates/RU) test ortamında denendikten sonra planlı bir bakım penceresinde canlı ortama uygulanmalı ve düzenli yama yönetim süreci oluşturulmalıdır.
- **Risk Seviyesi: High**

Bulgu 4.6.2 - Database Link Üzerinde Ayrıcalıklı Hesap Kullanımı: Diğer sistemlerle entegrasyonu sağlayan Database Link yapılandırmalarında LEGACY_LINK bağlantısının bağlanma kullanıcısı olarak SYS hesabını kullandığı belirlenmiştir.

- **Risk:** Bağlı olan "Legacy" sistemin ele geçirilmesi durumunda saldırgan doğrudan asıl veritabanında en yüksek yetkilerle işlem yapabilir.
- **Öneri:** Database Link yapılarında süper kullanıcı hesapları kullanılmamalı; yalnızca entegrasyon için gerekli tablolara yetkili özel entegrasyon hesapları oluşturulmalıdır.
- **Risk Seviyesi: High**

4.7 Değişiklik Yönetimi İhlalleri

Bulgu 4.7.1 - Canlı Ortamda Onaysız Değişiklik Uygulamaları: Değişiklik kayıtları (Change Log) incelendiğinde CHG-1003 (Yetki Değişikliği) ve CHG-1004 (Prosedür Güncellemesi) işlemlerinin onaylanmamış (NO) olmasına rağmen gerçekleştirildiği tespit edilmiştir.

- **Risk:** Onaysız yapılan yetki ve kod değişiklikleri sistem kararlılığını bozabilir, gizli arka kapılar (backdoor) oluşturabilir ve BT hizmet yönetimi (ITSM) süreçlerini ihlal eder.
- **Öneri:** CHG-1003 ve CHG-1004 acilen incelenmeli, gerekiyorsa geri alınmalıdır (rollback). Tüm değişiklikler Değişiklik Danışma Kurulu (Change Advisory Board - CAB) onay sürecine tabi tutulmalıdır.
- **Risk Seviyesi: High**

5. Risk Değerlendirmesi

Risk Kategorisi	Risk Seviyesi	Zafiyet Açıklaması ve Olası Etki
Hassas Veri İhlali (PCI-DSS / KVKK)	**Critical**	Şifresiz tablespace'ler ve açık metin kredi kartı, T.C. Kimlik No ve maaş verileri, yasal yaptırımlara ve itibar kaybına yol açar.
Yetki Yükseltme ve İç Tehdit	**Critical**	DBA rolüne sahip uygulama/danışman hesapları ve SYS kullanan LEGACY_LINK ile veritabanı tamamen ele geçirilebilir.
Kaba Kuvvet Saldırıları	**Critical**	Sınırsız deneme hakkı, zayıf hash'ler ve SYS'e yönelik 324 başarısız giriş aktif saldırı ihtimalini gösterir.
İzlenebilirlik (Accountability)	**Critical**	audit_trail = NONE olduğu için bir ihlal anında failin bulunması ve delil toplanması imkansızdır.
Veri Kaybı (Süreklilik)	**Critical**	17 Kasım 2025'ten beri yedek alınmaması ve şifresiz yedekler, fidye yazılımında geri dönülemez kayba neden olur.
Değişiklik ve Yama Yönetimi	**High**	Onaysız değişiklikler ve yamasız 19.3.0.0 sürümü, arka kapı ve bilinen CVE istismarı riskini artırır.

6. Sonuç

Sayın DataVault Bank Yönetimi,

Bu rapordaki bulgular; DataVault Bank'ın mevzuata (KVKK/GDPR vb.), PCI-DSS gibi sektörel standartlara ve bilgi güvenliği politikalarına uyum sağlayabilmesi için acil aksiyon planları oluşturulmasını gerektirmektedir. Veritabanı yöneticilerinin verdiği sekiz güvencenin hiçbiri teknik kanıtlarla doğrulanamamıştır. Tüm bulguların çözümü için veritabanı, güvenlik ve yönetim ekiplerinin eşgüdümlü çalışması önem arz etmektedir.

Acil Aksiyon Planı (Öneri): Öncelikle DBA rolü yetkisiz hesaplardan alınmalı ve atıl hesaplar kilitlenmeli, SYS hesabına yönelik başarısız girişler incelenmeli, denetim izleri aktif edilmeli, şifrelenmiş güncel bir yedek alınmalı ve kredi kartı verileri şifreleme/maskeleme ile korunmalıdır.